技術計畫書 · TECHNICAL PLAN

Email 送達問題排除計畫書

學員收不到（或太晚收到）登入驗證碼與每週報告信

專案	Ipsen Taiwan × Tan Yee Ming 八週 PERMA 幸福感課程
系統	coach 平台（Vercel 前端 · Render 後端 · Supabase 資料庫與認證）
日期	2026 年 8 月 3 日
版本	v1.0

一頁摘要

問題：學員的登入驗證碼被公司郵件閘道攔截或延遲放行，等收到時驗證碼已過期（預設 1 小時）而無法登入。

根因：驗證碼信目前由 Supabase 內建寄信服務發出，寄件網域是共用的 `supabase.io`，**沒有本專案的 SPF / DKIM / DMARC 簽章**，企業級郵件閘道（藥廠標配）會直接隔離。 這與後端每週報告信是**兩條不同的管道**——報告信已走自有網域，驗證碼信沒有。

建議：把 Supabase 認證信改走已完成網域驗證的 Brevo（`psybypsy.com`），與報告信使用同一組 DKIM 簽章。預估 **30 分鐘**，不需改動任何程式碼、不需資料庫遷移、可隨時回滾。 另外三項輔助措施合計約 10 分鐘。

01 現況與影響

本平台採無密碼登入：學員輸入 email，系統寄出一封含 6 位數驗證碼的信， 輸入驗證碼即完成登入。這個設計本身是為了解決「手機 email App 內建瀏覽器導致 session 留不住」的問題， 方向沒有錯，但它把**登入的成敗完全綁在信件送達率上**。

目前回報的狀況是：信件被對方公司的郵件系統攔下，等到實際收到時驗證碼已經失效。

受影響環節	目前狀態	後果
登入驗證碼	**已發生問題**	學員無法登入，等同無法使用整個平台
每週報告信（含 PDF）	**風險相同**	課程的核心交付物送不到，學員感受不到課程價值
每週書寫提醒信	**風險相同**	學員忘記書寫，週報告與教練深度分析都跟著缺一週

> **關鍵認知**
> 這不是「驗證碼有效期太短」的問題，而是**整個專案的信件送達率**問題。 就算把驗證碼有效期延長，報告信與提醒信一樣會被擋。 因此本計畫的第一優先是修送達率，不是修有效期。

02 根因分析

本專案目前有**兩條各自獨立的寄信管道**，兩條的健康狀況完全不同，這是問題的核心：

信件種類	目前走哪條路	寄件網域	驗證狀態
每週報告信 每週提醒信	後端 `backend/app.py` → Brevo HTTP API	`psybypsy.com`	**SPF / DKIM / DMARC 已驗證**
登入驗證碼	Supabase Auth → **內建寄信服務**	`mail.app.supabase.io`	**無本專案簽章（共用網域）**

為什麼內建服務註定被擋

Supabase 官方文件對內建寄信服務有三項明確限制：只寄給專案團隊成員的預授權地址、 **每小時上限 2 封**、**不提供任何投遞或運作時間的 SLA**，並直接註明「不適合正式環境使用」。

對郵件閘道而言，一封來自共用網域、沒有寄件方 DKIM 簽章、內容含有登入連結的信， 命中釣魚特徵的分數很高。藥廠的資安政策通常比一般企業更嚴格，隔離幾乎是必然結果。

第二個獨立成因：連結預抓

Supabase 官方把 **email 預抓（prefetching）**列為驗證碼失效錯誤的首要原因。 企業郵件安全服務（如 Microsoft Defender Safe Links）會自動點開信中每一條連結做威脅檢測。

本專案的信件樣板**同時包含 magic link 與 6 位數驗證碼，兩者共用同一個 token**。 掃描器點開連結時 token 即被消耗，**同一封信裡的驗證碼也一併失效**。 學員看到的現象是「信明明剛收到，輸入驗證碼卻說已過期」——這種

情況延長有效期完全無效。

03 行動計畫

優先	工作項目	預估	解決什麼
P1	**Supabase 認證信改走 Brevo SMTP**	30 分鐘	治本。驗證碼信改用已驗證網域與 DKIM 簽章，與報告信同一條信譽基礎
P2	信件樣板移除 magic link，只保留驗證碼	5 分鐘	杜絕掃描器預抓消耗 token；同時降低釣魚判定分數
P3	驗證碼有效期 1 小時 → 24 小時	2 分鐘	吸收閘道「先隔離、稍後放行」造成的延遲
P4	請 Ipsen IT 將寄件網域加入允許清單	依對方	唯一能「保證」不被攔截的手段；範本見附錄 A

實施條件

P1 至 P3 **皆不需改動任何程式碼、不需資料庫遷移、不影響已登入的學員**， 全部在 Supabase 與 Brevo 的後台完成，且可隨時關閉回到原狀。

P4 需要對方公司配合，時程不可控，因此不列為前置條件。 P1 至 P3 完成後應先實測，若仍被攔截再啟動 P4。

04 P1 詳細操作步驟

前提：Brevo 帳號已開通 transactional、`psybypsy.com` 網域驗證已完成。 後端報告信目前寄得出去，即代表這兩項皆已滿足。

先釐清一個容易混淆的點

後端報告信走的是 Brevo 的 **HTTP API**（因為 Render 免費方案封鎖 SMTP 埠 25 / 465 / 587）。 本步驟要設定的是 Supabase 走 Brevo 的 **SMTP**。兩條路並存、互不影響， `backend/app.py` 一行都不需要改。Supabase 的寄信伺服器不在 Render 上，連 SMTP 埠沒有問題。

1 在 Brevo 取得 SMTP 憑證

`Brevo → 右上頭像選單 → SMTP & API → SMTP 分頁`

這一頁提供兩個值：**SMTP 登入帳號**（格式類似 `9xxxxx001@smtp-brevo.com`）與 **SMTP key**（按 Generate a new SMTP key 產生，產生後立即複製，關閉即無法再檢視）。

最常見的錯誤

SMTP key 不是 API key。Brevo 介面上兩者位置相鄰、外觀相似。 後端目前使用的那把是 API key，**不能用在這裡**。拿錯會得到 `535` 認證失敗。

2 確認 IP 封鎖對 SMTP 也已停用

```
Brevo → Settings → Security → Authorized IPs
```

先前為了後端 API 已停用過 IP 封鎖，但 **SMTP 是獨立的一列，必須再確認一次**。

Supabase 的寄信伺服器使用雲端浮動 IP，無法列入白名單。此項未停用時的症狀同樣是 `535`，且錯誤訊息不會指出是 IP 問題，極難自行判讀。

3 在 Supabase 啟用 Custom SMTP

```
Supabase Dashboard → Authentication → Emails → SMTP Settings → 開啟 Enable Custom SMTP
```

欄位	填入值
Sender email	`report@psybypsy.com`（或另建 `login@psybypsy.com`，須在同一已驗證網域下）
Sender name	與每週報告信一致
Host	`smtp-relay.brevo.com`
Port number	`587`（STARTTLS）
Username	步驟 1 的 SMTP 登入帳號
Password	步驟 1 的 SMTP key

貼上 key 時**不可帶入前後空白或換行**，多一個字元即為 `535`， 且錯誤訊息同樣模糊。建議貼上後以 End 鍵確認游標落點。

4 調高寄信速率上限

```
Supabase → Authentication → Rate Limits → Rate limit for sending emails
```

啟用 Custom SMTP 後 Supabase 預設為**每小時 30 封**。同一梯次學員集中登入時可能不足， 建議調整為 100。Brevo 免費方案為每日 300 封，登入信與報告信共用此額度，以目前規模仍寬裕。

5 移除樣板中的 magic link（P2）

```
Supabase → Authentication → Emails → Magic Link 樣板
```

刪除連結，僅保留驗證碼：

```
<p>你的登入驗證碼：</p>
<p style="font-size:24px;font-weight:bold;letter-spacing:4px">{{ .Token }}</p>
```

沒有連結可供掃描，token 就只有學員本人用得到。 另可參考 `docs/persistent-login.md`：magic link 在手機上會開啟於 email App 的內建瀏覽器、 session 留不住，本來就不是建議的登入路徑。

6 延長驗證碼有效期（P3）

```
Supabase → Authentication → Sign In / Providers → Email → Email OTP expiration
```

由預設 `3600`（1 小時）改為 `86400`（24 小時）。

這是 Supabase 允許的上限——超過一天只能透過 Management API 設定，且官方強烈不建議 （有效期越長，暴力破解的時間窗越大）。**「永不過期」沒有這個選項。**

此設定同時作用於 magic link、註冊確認信、邀請信與重設密碼連結。 Supabase 的 Security Advisor 會對超過 1 小時的設定顯示警告，該警告不會阻擋功能。

05 驗收標準

依序完成四項檢查，**前三項只證明設定正確，第四項才是真正的驗收**：

#	檢查動作	通過條件
1	用自有 Gmail 於登入頁請求驗證碼	收得到信
2	檢視該信的寄件者	網域為 `psybypsy.com`，**不是** `supabase.io`
3	Brevo → Transactional → Logs	該封信出現在紀錄中，狀態為 `delivered`
4	**用 Ipsen 的信箱實測一次**	於有效期內收到並成功登入

若第 3 項有紀錄、第 4 項仍未收到，即可確認信件已成功送出、是對方端攔截， 排查範圍縮小至 Ipsen 的郵件政策，此時啟動 P4（附錄 A）。

疑難排解對照

症狀	原因
`535 authentication failed`	拿到 API key 而非 SMTP key；或 key 含多餘空白；或步驟 2 的 IP 封鎖未停用
Supabase 顯示已寄出，Brevo Logs 無紀錄	認證未通過，同上一列處理
Brevo Logs 顯示 `blocked` 或 `hard bounce`	收件端拒收，與本端設定無關，須走 P4 白名單
寄件者仍為 `supabase.io`	Custom SMTP 未儲存成功，回步驟 3 確認開關狀態

06 風險與回滾

風險	程度	處置
SMTP 憑證設定錯誤導致所有認證信中斷	中	驗收第 1 至 3 項會立即發現；關閉 Custom SMTP 即刻復原
Brevo 每日 300 封額度被登入信與報告信共同耗盡	低	以現行學員規模不會觸及；如需擴大梯次再評估付費方案
驗證碼有效期 24 小時降低安全強度	低	屬 Supabase 官方允許範圍上限；驗證碼為單次使用，且本專案有 `allowed_emails` 白名單把關
Ipsen IT 拒絕加入白名單	中	見第 07 節備案

回滾方式

關閉 **Enable Custom SMTP** 即回到內建服務。不影響資料庫、不影響已登入的 session、 不需重新部署前後端。三項設定皆可獨立回復。

07 備案：改採帳號密碼登入

若 P1 至 P4 全數執行後仍無法穩定送達，可評估改用密碼登入，使**登入環節完全不依賴 email**。 本專案已具備 `allowed_emails` 白名單與 `handle_new_user()` trigger， 為封閉制梯次，架構上適合密碼登入。

但必須認清其範圍

密碼登入**只解決登入**。每週報告信與提醒信仍走 email， 所以 P1 的 Brevo 設定**無論如何都必須完成**，不能以密碼登入取代。

衍生問題	因應
初始密碼如何交付	由管理者以 Admin API 預建帳號並設定初始密碼，**透過 email 以外的管道**交付（現場、通訊軟體、簡訊）。若仍以 email 寄送則問題原封不動
忘記密碼	重設信同樣會被攔截，只能人工重設。八週梯次期間必然發生，屬長期營運負擔
安全強度	無 MFA、可能使用弱密碼。須開啟 Supabase 的 Leaked Password Protection 並設定最短長度

建議做法為兩者並存而非二擇一。Supabase 同一個 Email provider 同時支援 `verifyOtp` 與 `signInWithPassword`，可讓收得到信的學員繼續使用驗證碼， 被攔截的學員改用密碼。前端改動集中於 `src/routes/login.tsx`， 連同首次登入強制改密碼的流程，預估半天至一天。

附錄 A　致 Ipsen IT 的白名單申請範本

P4 使用。以下內容可直接複製寄給對方 IT 窗口，已包含資安人員判斷所需的資訊。

主旨

申請將 psybypsy.com 加入郵件允許清單（員工健康課程系統通知信）

您好，

敝單位為貴公司同仁提供為期八週的職場幸福感（PERMA）課程， 課程平台需寄送兩類信件給參與的同仁，目前疑似遭郵件閘道攔截或延遲放行， 導致同仁無法完成登入。懇請協助評估將本寄件網域加入允許清單。

寄件資訊

- 寄件網域：`psybypsy.com`
- 寄件位址：`report@psybypsy.com`
- 寄送服務商：Brevo（transactional email）
- 驗證狀態：SPF、DKIM、DMARC 均已於該網域完成設定並通過驗證

信件用途

- 登入驗證碼：6 位數一次性密碼，同仁主動於登入頁請求時才寄出
- 每週個人回顧報告：附 PDF，一位同仁每週一封

其他說明

- 收件對象僅限已報名本課程的同仁，非群發、非行銷性質
- 預估總量低於每月 100 封
- 信件內不含外部登入連結（僅含純文字驗證碼），以避免與貴公司的連結掃描機制衝突

如需補充任何技術資訊或安排測試信，敬請告知，我方可全力配合。

謝謝您的協助。

寄送前請確認

最後一項「信件內不含外部登入連結」的前提是 **P2 已完成**（樣板已移除 magic link）。 若尚未執行，請先完成 P2 再寄出本信，避免對方測試時發現與說明不符。

附錄 B 相關文件與程式位置

項目	位置
Brevo 帳號與網域驗證設定紀錄	`docs/brevo-setup.md`
持久登入與 session 設定說明	`docs/persistent-login.md`
報告產生與寄送流程	`docs/report-flow.md`
登入頁（驗證碼與 magic link 兩條路徑）	`src/routes/login.tsx`
後端寄信（Brevo HTTP API）	`backend/app.py` — `_mail_channel()`、`_email_report()`
Email 白名單與新使用者 trigger	`supabase/schema.sql` — `allowed_emails`、`handle_new_user()`